

What has happened?

- During working hours, HaiTek employees carried out maintenance work related to the flight information displays
- After the workday, an attack was carried out against a HaiTek computer (192.0.2.80 → 198.51.100.2) by exploiting the EternalBlue vulnerability, and a remote administration connection was established to the computer (the HaiTek employee's workstation was compromised)
- Later in the evening, attempts were first made to access the AirPortSys1 and AirPortSys2 systems using higher-privileged user accounts (root and admin). After several failed login attempts, the credentials of the employee whose computer had been compromised were tried, and access was gained after a few attempts
- After this, the attacker made changes to the database that caused the flight information displays to show incorrect information

Klo 18:02-18:03: HaiTek's network is scanned from outside the network. IP addresses 198.51.100.1 → 198.51.100.20 are targeted, and 198.51.100.20 is the first address to respond to the scan

Klo 18:06: HaiTek's network monitoring system detects an attempt to exploit the EternalBlue vulnerability

Klo 18:14: A remote administration connection is established to the computer at 198.51.100.20

Klo 16:36 – 22:58: A VPN connection to 10.20.31.2 (the VPN address of 198.51.100.20) is maintained

Klo 22:37-22:57: The AirPortSys1- and AirPortSys2 log files show login attempts for several different users within a short period of time (root, admin, tahvo)

Klo 22:38: Access to the AirPortSys2 system is gained using the tahvo user account

Klo 22:58: The VPN connection to 10.20.31.2 is terminated

Follow-up Actions

- Immediately:
 - Terminate VPN connections to HaiTek (10.20.31.2–30).
 - Change the passwords of all administrative users on AirPortSys1 and AirPortSys2.
 - Create and preserve a complete system image before performing any restoration.
 - Request system backups from HaiTek and restore them to the systems (disconnect the network during the restoration and reconnect it in a controlled manner).
- After restoration:
 - Compare the files and configurations of the restored systems with the current systems, and analyze and document any differences as possible traces caused by the attack.
 - Implement a more comprehensive monitoring system for the airport systems.
- Later:
 - Contact HaiTek and require an investigation and a separate security audit regarding the follow-up actions.
 - Ensure that HaiTek doesn't establish any new VPN connections before receiving approval from NanInt management.
 - Reassess the security of the maintenance model.